BrightAI · Saudi AI Safety OS

CHAMPIONSHIP AUDIT · v3

تقرير البطولة v3

من "إصلاح" إلى "بطولة": الطريق إلى #1 في حوكمة الذكاء الاصطناعي بالسعودية

الموقع: https://brightai.site · التاريخ: 29-07-2026 · آخر نشر: a8857c26

v1 — أول تدقيق

14%

إنتاج مرجّح · 07-2026

v2 — بعد 79 بروميت

14%

صفر تغيّر إنتاجي

v3 — البطولة

47.5%

▲ +33.6 نقطة — أول تحرك فعلي

كود v3 (CODE)

73%

جاهز للنشر

⚠️ **تحذير أمني (P0):** لقطة شاشة المالك كشفت قيمة `GEMINI_API_KEY` كاملة (تبدأ بـ `AIza...`). يجب تدويرها فورًا من Google AI Studio حتى لو لم تظهر في الريبو. القيمة القديمة `AIzaSyC3pLdZ...` لا تزال نصًا صريحًا في `.agents/brain.md:4373` + 3 تقارير متعقّبة في `.git`.

جدول المحتويات

- 1. الحكم التنفيذي (Executive Verdict)
- 2. جدول Delta الكلي: v1 → v2 → v3
- 3. المرحلة أ — Deployment Forensics + جدول الحقيقة v3
- 4. المرحلة ب — الأمان و PDPL
- 5. المرحلة ج — الفهرسة والزحف
- 6. المرحلة د — Saudi Championship محور جديد
- 7. المرحلة هـ — Kernel Product Championship محور جديد
- 8. المرحلة و — التصميم و UX والهوية
- 9. المرحلة ز — البنية والكود
- 10. Top 15 قاتل (Killers)
- 11. خارطة الطريق: Saudi + Kernel Championship (90 يومًا)
- 12. خطة Gemini API Integration + Mobile Checklist
- 13. خرائط P0/P1/P2/P3 + المخاطر + ما يجب ألا يُلمس
- — ملحق — أوامر curl + فجوات البيانات + القائمة المرجعية

1. الحكم التنفيذي

الإنتاج تحرّك لأول مرة. بعد دورتين تدقيق (v1=14%، v2=14%) كان فيهما نفس النتيجة — كود يتقدّم لكن الإنتاج جامد — نجح v3 أخيرًا في كسر الجمود: الإنتاج قفز إلى **47.5%** (+33.6 نقطة). هذا ليس تحسينًا تدريجيًا، بل تصحيح جوهري: `homepage last-modified` اليوم، `/frontend/server.js` تسريب انحل (404)، الـ 6 ترويسات الأمنية كلها حاضرة، redirects الـ `/blog` تعمل (301)، و hreflang الـ `/en/` سليم ثنائي الاتجاه.

لكن v3 قفز على ساق واحدة. الكود الحالي يخدم 73% جاهزية — فيه AI Firewall + quota + circuit breaker + Gemini حقيقي يقرأ `process.env` في runtime. المشكلة الحرجة: **النشر المنشور على Render مُعدّ كـ Static Site بدل Node Web Service**، رغم أن `render.yaml` يصف `runtime: node`. نتيجة ذلك: كل `/api/*` endpoints (chat, lead, csrf, health) تخدم **empty 200** على POST و 404 على GET — أي أن **الـ Kernel منتج وهمي بالكامل في الإنتاج**: الواجهة تسقط بأمان إلى `FAKE_RESPONSES` demo mode ثابتة)، لكن المستخدم الحقيقي لا يتحدث مع Gemini أبدًا.

القرار المتبقي واحد فقط: نشر. 90% من العمل الهندسي منجز؛ المتبقي قرار نشر على Render (ساعة واحدة تقريبًا): تحويل الخدمة إلى `node ./dist/server/entry.mjs` + ضبط متغيرات البيئة الإنتاجية. بعدها يصير `/kernel/chat/` منتجًا حقيقيًا متصلًا بـ Gemini — وهذا هو محور البطولة في v3.

الفجوة الثانية للبطولة: الثقة (E-E-A-T). السوق السعودي في حوكمة AI شبه خالٍ من المنافس "المنتج" (الكل استشاريون أو جهات تنظيمية أو منتجات privacy فقط). BrightAI يتصدر فعليًا كلمتين ("حوكمة الذكاء الاصطناعي السعودية"، "AI Firewall السعودية"). لكنه **يغيب عن كلمات الطلب العالي** (PDPL، ECC، حوكمة AI للبنوك) ويفتقد إثبات الكيان: لا سجل تجاري، اسم المؤسس "يزيد" فقط في JSON-LD، لا صورة، لا عملاء مسمّين، لا `/answer/*`. هذه 5 خطوات ترفع `Saudi Championship` من 56 إلى ~88.

47.5%	73%	33.6+	1	195
إنتاج v3 (مرجّح)	كود v3 جاهز	نقاط Δ منذ v2	قرار نشر يفصل 73% عن 100%	URL في sitemap

13
صفحة Kernel (demo فقط)

2. جدول Delta الكلي: v3 → v2 → v1

ملاحظة منهجية: v1/v2 استعملا 6 محاور وأوزانًا مختلفة (Indexation 25%, Security 20%). v3 يضيف محورين جديدين (+ SaudiChampionship KernelChampionship) ويعيد توزيع الأوزان لتعكس أولوية "البطولة لا الإصلاح". الدرجات على الإنتاج (PROD) هي المعيار الوحيد للحقيقة. *[ثقة: 90%]*

المحور	الوزن	v1 إنتاج	v2 إنتاج	v3 إنتاج	v3 كود	Δ v2→v3	أقسى حقيقة
Deployment Forensics	15%	5%	5%	50%	85%	▲ 45+	النشر فعلي الآن؛ لكن `Render service = Static` كل `Site` بدل Node → `/api/*` ميت
Security & PDPL	15%	15%	15%	35%	80%	▲ 20+	6 headers حاضرة + CSP، لكن مفتاح Gemini قديم نصًا صريحًا في `brain.md` و الـ `/api/*` لا يُنفّذ
Indexation & Crawling	15%	1%	1%	25%	70%	▲ 24+	sitemap لـ 195 URL و hreflang سليم، لكن **كل lastmod = تاريخ البناء** و redirects مخصصة مكسورة (404→)
Saudi Championship جديد	25%	5%	5%	56%	60%	▲ 51+	يتصدر كلمتين ناشئتين، لكن لا سجل تجاري ولا اسم مؤسس كامل ولا عملاء مسمّين
Kernel Championship جديد	10%	—	—	45%	80%	جديد	كود من فئة إنتاجية، لكن **الإنتاج = demo وهمي بالكامل** (Node server لا يعمل)
Design / UX / Identity	10%	45%	45%	70%	75%	▲ 25+	RTL نظيف (206 / 0 logical)، خطوط self-hosted، trust badges حاضرة نصًا
Code / Structure	10%	50%	50%	55%	70%	▲ 5+	TS strict + CI gates قوية، لكن `lint:legacy=echo` + `chat.ts` 1290 سطر + `vitest` config معطّل
الإجمالي المرجّح	**100%**	**14%**	**14%**	**47.5%**	**73%**	**▲ 33.6+**	**أول قفزة إنتاجية حقيقية منذ التأسيس**

القصة المركزية لـ Delta

في v1 و v2، الكود تحسّن من 55% إلى 70% لكن الإنتاج بقي جامدًا على 14% لأن صفر عمليات نشر وصلت. في v3 حدث النشر أخيرًا (آخر commit `a8857c26` اليوم) — فقفز الإنتاج +33.6 نقطة. لكن النشر نفسه **ناقص**: خدمة Render مُعدّة كـ Static Site بدل Node، فيعمل كل ما هو static (HTML/headers/redirects الأساسية) لكن تتعطل كل مسارات الـ `/api/*` (SSR). تصحيح واحد لهذه الإعداد = +20-25 نقطة فورية.

3. المرحلة أ — Deployment Forensics + جدول الحقيقة v3

المنهجية: لكل ادعاء نشر، نقارن SOURCE_STATE (في الكود) مع PROD_STATE (curl على brightai.site). إن اختلفا = FAILED — NOT DEPLOYED.

3.1 جدول الحقيقة (Deployment Truth Table v3)

الادعاء	SOURCE_STATE	PROD_STATE (curl)	الحكم
الرئيسية منشورة وفاعلة	src/pages/index.astro (761 سطر، 16 section)	HTTP 200, last-modified 2026-07-29 20:19	PASS
تسريب /frontend/server.js	frontend/server.js (Express backend)	HTTP 404 (انحل منذ v1)	PASS
10 مسارات مصدر ممنوعة (render.yaml, .env, config.js…)	deny-list.mjs patterns	/frontend/package.json 404, /render.yaml 404, /client/index.html 404	PASS
/api/health/ فاعل (Render healthcheck)	src/pages/api/health.ts, render.yaml:15 healthCheckPath	HTTP 404 (يخدم HTML 404 معرّب، ليس JSON)	FAILED
/api/ai/chat/ متصل بـ Gemini	chat.ts:369 process.env.GEMINI_API_KEY, dist/server/entry.mjs مبني	POST → 200, content-length:0, لا content-type. GET → 404. لا streaming.	FAILED
/api/lead/ يرجع JSON صريح (PDPL)	src/pages/api/lead.ts (337 سطر, CSRF+rate limit)	POST → 200, content-length:0. silent من أي Origin.	FAILED
/blog redirects و /about (no-slash)	trailingSlash:'always' in astro.config	/blog → 301 → /blog/, /about → 301	PASS
redirects مخصصة في _redirects	public/_redirects (216 134 سطر، قاعدة .html)	/report → /report/ → 404 (dest لا يُطبّق). /blog.html → 404	FAILED
ترويسات الأمن الست	public/_headers + middleware + CF Transform	HSTS+preload, X-Frame, nosniff, Referrer, Permissions كلها حاضرة	PASS
sitemap شامل	scripts/generate-sitemap-all-pages.mjs	195 URL + 195 lastmod (لكن كلها نفس التاريخ)	*PASS
lastmod per-page (git log)	contract lines 21-29: "derived from git log"	195 entry 29-07-2026 كلها (تاريخ البناء فقط)	FAILED
/en/ hreflang ثنائي الاتجاه	src/data/hreflang-pairs.ts (bidirectional)	/en/privacy-policy self=en-SA ✓, /privacy-policy peer=en-SA ✓	PASS

*PASS ببنية، لكن lastmod مكسور (انظر المرحلة ج).

3.2 التشخيص الجذري: Static Site بدل Node Service

CRITICAL — Deployment Drift

المشكلة: astro.config.mjs:230 يصرّح output:'static' مع adapter: node({mode:'standalone'}) (نموذج Astro 5/6 hybrid صحيح: static افتراضيًا + opt-in SSR عبر prerender=false). كل routes الـ /api/* معلّمة export const

`render.yaml:11-15` يصف `type:web, runtime:node, startCommand: node ./dist/server/entry.mjs` مبني وملتزم في git (يحوي 3 مراجع لمسار chat). `prerender = false`، و `dist/server/entry.mjs`.

لكن الإنتاج الفعلي: ردود `POST /api/*` تحمل هيدر `rndr-id` (بصمة Render **Static Site**)، وغياب هيدر `x-brightai-build` الذي يُحقنه `entry.mjs` في كل طلب. النتيجة: **الخدمة المنشورة مُعدّة كـ Static Site رغم أن render.yaml يصف Node**. انحراف نشر (deployment drift) بين الـ blueprint المُلتزم والخدمة الفعلية على لوحة Render.

الدليل القاطع: `rndr-id` في كل رد `/api/*` + غياب `x-brightai-build` + empty-200 على POST من *أي* Origin (الـ Origin allowlist في chat.ts:217 لو كان شغّالًا لرجع 403).

Deployment Integrity Score 3.3

البنود الناجحة فعلًا في الإنتاج ÷ البنود المُعلنة = **7/12 = 58%** (كان 1/8 = 12.5% في v1، و ~1/8 في v2). تحسّن كبير، لكن الـ 5 بنود الفاشلة كلها في الـ SSR layer — وهي قلب المنتج.

4. المرحلة ب — الأمان و PDPL

4.1 B1 — تسريب مفتاح Gemini

القيمة	الموقع	متتبّع في git؟	الحكم
AIzaSyC3pLdZ-7R2XlvPFTZ8Alg93zkuThHbQYM (قديم)	.agents/brain.md:4373	نعم (في HEAD a8857c26، دخل عبر 3f49dd81)	FAIL — high
AIzaSyC3pLdZ… (نفسه)	report/A/2026-07-15-kernel-audit-master.md:119	نعم	FAIL
AIzaSyC3pLdZ… (نفسه)	report/A/2026-07-18-pre-audit-brain-snapshot.md:1320	نعم	FAIL
AIzaSyC3pLdZ… (نفسه)	brightai-audit-reports/prompt/brightai-audit-prompts.md:289	نعم	FAIL
AIzaSyC3pLdZ… (نفسه)	.env:5	لا (gitignored)	local only
AIzaSyBFMm… (جديد من لقطة الشاشة)	صفر مطابقات في working tree + git log --all -S	لا	PASS — clean

المفتاح القديم CONSUMER_SUSPENDED عند Google (غير قابل للاستخدام)، لكن تعرّضه النصّي في تاريخ git باقٍ. المفتاح الجديد نظيف في الريبو — لكن **لقطة الشاشة التي قدّمها المالك كشفت قيمته كاملة** → يجب تدويره بغض النظر عن الريبو.

4.2 B2 — تحصين /api/* (مراجعة الكود)

الكود مُحصّن بشكل شامل — لكنه **غير مُنفّذ في الإنتاج** (انظر المرحلة أ). هذا يجعل كل ضوابط الأمان *خاملة*.

الضابط	الموقع في chat.ts	الحكم (كود)	الحكم (إنتاج)
عزل المفتاح (لا تسريب للـ client)	responses use sanitized codes (provider_failed…)	PASS	N/A — لا يعمل
Rate limit + quota (Redis, multi-dim)	checkQuota({ip,sessionId}) line 808	PASS	dormant
CORS/Origin allowlist	ALLOWED_ORIGINS line 182-188	PASS	dormant (Origin → 200 أي)
Input validation (≤4000 chars, no systemPrompt)	line 700-715	PASS	dormant
AI Firewall (provider قبل PII redaction)	runFirewallSync line 739, block→451, approval→428	PASS	dormant
fallback Groq→Gemini + circuit breaker	isProviderOpen/recordProviderFailure line 906-940	PASS	dormant
CSRF (lead.ts double-submit)	verifyCsrfRequest line 196	PASS	dormant
body size limit على /api/*	— غير موجود —	MISSING	N/A

B3 — CSP Strictness (Phase 2) 4.3

الإنتاج يخدم `unsafe-inline` — `script-src 'self' 'unsafe-inline'` لازال. السبب: `<script>` `inline` 15 في صفحات kernel تستخدم `public/_headers:60-71`. `define:vars` يوثّق هذا كقرار Phase 1 صريح، مع Phase 2 (nonce-based) معلّقة تتطلب إعادة كتابة ~30 ملف. **PARTIAL — medium**

B5 4.4 — الترويسات الأمنية (نجاح كامل)

الترويسة	القيمة في الإنتاج	الحكم
strict-transport-security	`max-age=63072000; includeSubDomains; preload`	PASS
x-frame-options	`SAMEORIGIN (+ CSP frame-ancestors 'self')`	PASS
x-content-type-options	`nosniff`	PASS
referrer-policy	`strict-origin-when-cross-origin`	PASS
permissions-policy	`camera=(), microphone=(), geolocation=()`	PASS

HSTS preload جاهز في الهيدر، لكن **التسليم في hstspreload.org خطوة يدوية لم تُؤكّد**.

B4 — القاتل: `/api/*` endpoints/ معطّلة بالكامل

كل POST إلى `/api/ai/chat/` أو `/api/lead/` من *أي* Origin (حتى `evil.com`) يرجع **200 silent فارغ**. هذا يعني: لا rate limit، لا CSRF، لا firewall، لا Origin check، لا validation — كلها موجودة في الكود لكنها **خاملة**. من منظور PDPL (المادة 16 — المساءلة)، silent-200 `/api/lead/` = فشل الإفصاح الصريح للمرسل.

5. المرحلة ج — الفهرسة والزحف

5.1 C1 — sitemap: lastmod مكسور (HIGH)

contradction موثّقة

`scripts/generate-sitemap-all-pages.mjs:21-29` يصرّح: *"lastmod is derived from git log ... never from the build timestamp"*. الـ sitemap المحلي يحوي **9 تواريخ فريدة** (13-06-2026 → 29-07-2026). لكن الإنتاج يخدم **195 entry كلها 2026-29-07** (تاريخ البناء). Google سيتجاهل lastmod لعدم مصداقيته → يُلغي إشارة freshness. الـ contract مكسور في الإنتاج.

5.2 C2 — hreflang (سليم) + حدود

7 أزواج مزدوجة فقط (homepage + 5 legal + sales-deck). bidirectional مؤكّد. لكن **kernel (11 صفحة) وكل الصفحات بلا en-SA** — قرار محتوى موثّق (`hreflang-pairs.ts:102-108` "no invented English peer"). MEDIUM

5.3 C3 — redirects مكسورة (HIGH)

المسار	المتوقع في _redirects	الفعلي على الإنتاج	الحكم
`/report`	`301 → /trust/`	`301 → /report/ → 404`	dest لا يُطبّق
`/blog/ai`	`301 → /404/`	`301 → /blog/ai/ → 404`	dest لا يُطبّق
`/blog.html`	— لا rule —	`404` مباشر	لا rule عام .html
`/blog`	trailing-slash normalization	`301 → /blog/` ✓	PASS

المضيف يطبّق فقط إعادة توجيه trailing-slash ويتجاهل الـ dest المخصصة في `_redirects`. النتيجة: روابط تؤدي لـ 404. سبب محتمل: `_redirects` معطّل على Render Static Site (يحتاج Cloudflare Transform Rule أو `astro.config redirects`).

5.4 C6-C8 — النجاحات

11/11	33	19	152
صفحة kernel index,follow	entry في kernel sitemap (11×3 hreflang)	نوع JSON-LD على الرئيسية	سطر في llms.txt

195
سطر في ai.txt

5.5 C9 — GSC [DATA GAP]

لا يتوفر وصول Google Search Console. التقدير الاستنتاجي: موقع بـ 195 URL، نشيط النشر (~آخر أسبوع)، فهرسة أولية محتملة لكن lastmod الموحّد يُضعف إشارة إعادة الزحف. **التوصية: ربط GSC + تصدير أسبوعي (`weekly-gsc.yml` workflow موجود لكن يحتاج `GSC_SERVICE_ACCOUNT_JSON`).**

6. المرحلة د — Saudi Championship محور جديد · 25%

السؤال المركزي: ما الذي يجعل BrightAI #1 في السعودية في حوكمة AI؟ النتيجة: **56/100** *[ثقة: عالية]*. البنية الفنية في المستوى الأعلى، لكن طبقة "إثبات الكيان" (E-E-A-T) في المستوى الأدنى.

6.1 المنافسة السعودية — فرصة احتكار حقيقية

لا يوجد منافس "منتج" سعودي في AI governance التشغيلية (AI Firewall + Audit Trail + Human Approval معًا). السوق منقسم:

المنافس	النوع	القوة	الضعف	علاقة BrightAI
SDAIA / NCA	حكومي منظّم	المرجع الرسمي (PDPL, ECC-2 Tool, ISO 42001 ذاتيًا)	أدوات تقييم، ليست منتج حوكمة AI تشغيلي	BrightAI = الطبقة التشغيلية التي تنظّمها
PwC / KPMG / EY Saudi	استشاري	أطر Responsible AI، علاقات تنفيذية	خدمات لا منتجات؛ دورة بيع طويلة	BrightAI = منتج مستمر لا مشروع محدود
OneTrust / Securiti.ai	منتج عالمي	منصة GRC/privacy ناضجة	تركيز privacy/PDPL لا AI governance؛ غربية	BrightAI = AI-native + سعودي
DataMost / Asas.ai / Sahl	منتج سعودي ناشئ	PDPL automation محلية	PDPL فقط، لا AI governance	منافس على كلمة PDPL فقط
ريناد المجد RMG	استشاري سعودي محلي	خدمات ISO 42001 + SAMA + حوكمة AI	خدمات/تدقيق ليست منصة	أقرب منافس محلي لكنه خدمات
bright.ai (أمريكي)	منتج	تمويل، Physical AI للبنية التحتية	مجال مختلف تمامًا، لا حضور سعودي	تشابه اسم فقط، لا منافسة

6.2 الكلمات السعودية المستهدفة *[ASSUMPTION — confidence 70% · WebSearch يوليو 2026]*

الكلمة	المنافس #1	وضع BrightAI	الفرصة
"حوكمة الذكاء الاصطناعي السعودية"	**BrightAI**	**متصدّر فعليًا**	الدفاع + الحفاظ
"AI Firewall" السعودية	**BrightAI (وحيد)**	**مصطلح ناشئ بلا منافسة**	احتكار + تعريف المصطلح
"نظام حماية البيانات الشخصية" PDPL	SDAIA + DataMost	**غائب عن أول 10 نتائج**	صفحة PDPL متعمقة
"ضوابط ECC"	NCA + CYBR + CyberArrow	**مكتظة بأدوات ECC**	منخفضة
"حوكمة AI للبنوك"	SAMA + RMG	**غائب رغم وجود solutions/banking-ai-/ /governance**	عالية — طلب تجاري كبير
"سدايا" / "SDAIA"	الجهة نفسها	**لا يمكن منافسة المنظّم على اسمه**	منعدمة

6.3 E-E-A-T — الفجوة الحرجة

الإشارة	الواقع	الأثر
اسم المؤسس في JSON-LD	**"يزيد" فقط (الاسم الأول) في Organization.founder.name — في**	**كيان مجهول يبيع للبنوك**

الإشارة	الواقع	الأثر
	homepage + about + schema-saudi-seo.json	
الاسم الكامل	"يزيد الشريف" في authors/yazeed-/alshareef/ لكن "يزيد الشمري" يظهر أيضًا في about (تناقض بيانات)	تشتت Knowledge Graph
رقم السجل التجاري	صفر عبر كل الصفحات + JSON-LD + llms.txt	حرج — لا بنك يتعامل بدون إثبات كيان قانوني
صورة المؤسس	avatar = حرف "ي" فقط، ليست <img>	ضعف Trust
السيرة المهنية	لا خبرات سابقة مسمّاة	ضعف Authority
شعارات عملاء	/customers/ = "بنك سعودي ريد"/"مستشفى كبير" (مجهول صراحةً)	صفر social proof
شهادات طرف ثالث	لا G2/Capterra/Clutch	صفر مراجعات موثقة
تغطية صحفية	صفر PR سعودي	ضعف Authority إقليمي
Google Business Profile	[DATA GAP] العنوان موحّد في JSON-LD لكن GBP غير قابل للتحقق بدون GMB access	محتمل ضعيف

6.4 AEO/GEO — قوة بنيوية + فجوة صفحات

نقطة قوة: llms.txt / ai.txt / llms-full.txt

`/llms.txt` (152 سطر، 14 قسم)، `/llms-full.txt` (372 سطر، 39 قسم)، `/ai.txt` (195 سطر). فيها Entity Facts كنونية + **Target AI Search Queries صريحة** (EN+AR) + AI Crawler Access Policy تفرّق بين Search/Grounding و Training. **أفضل من 95% من المواقع السعودية.**

فجوة: لا صفحات /answer/* و /lp/*

404 = `/lp/pdpl/`، 404 = `/answer/test/`، لا `FAQPage` مخصصة لأسئلة AI. **هذه الصفحات تتغذى منها Perplexity/ChatGPT مباشرة** — غيابها فجوة AEO كبيرة رغم llms.txt الممتاز.

[ASSUMPTION — confidence 30%]: ذكر BrightAI في ChatGPT/Perplexity غير قابل للاختبار هنا. بناءً على تصدّر WebSearch لكلمتين + llms.txt قوي لكن بلا mentions خارجية/backlinks/press — افتراض: ذكر ضعيف أو معدوم في AI engines.

6.5 Trust Signals للبنوك

ROI calculator موجودة على `/calculator/roi/` (محتوى غني: 12×calculator، 5×ROI، حاسبة18×) لكن **`/calculator/` الجذر = 404** (احتمال فقدان مستخدمين). لا trust badges بصرية على hero (الجهات مذكورة كنص في /trust/ فقط). llms.txt صريح وصادق: *"does NOT claim any specific certification ... unless a separate public certificate page states that explicitly"* — شفافية أخلاقية ممتازة لكن صفر badges ثقة بصرية للبنوك.

6.6 Saudi Championship Score: 56/100

البُعد	الوزن	النقاط	السبب
د.1 المنافسة (فرصة السوق)	25%	22/25	لا منافس منتج مباشر؛ فرصة احتكار

البُعد	الوزن	النقاط	السبب
د.2 SERP targeting	20%	10/20	متصدر كلمتين ناشئتين، غائب عن البنوك/PDPL/ECC
د.3 E-E-A-T	20%	**6/20**	اسم أول فقط، لا CR، لا صورة، لا سيرة، لا شعارات، لا شهادات، لا press
د.4 GBP/Local	5%	2/5	[DATA GAP] لكن العنوان موحّد JSON-LD
د.5 AEO/GEO	15%	11/15	llms.txt ممتاز لكن لا /answer/*
د.6 Trust للبنوك	15%	**5/15**	لا badges، لا عملاء مسمّين، لا CR

7. المرحلة هـ — Kernel Product Championship محور جديد · 10%

7.1 الجواب على السؤال المركزي

هل /kernel/chat/ متصل فعليًا بـ Gemini؟

لا. الكود من الفئة الإنتاجية بالكامل (SSE reader حقيقي + Gemini + quota + circuit breaker + AI Firewall يقرأ `process.env` في runtime)، لكن **الإنتاج يخدم الموقع كـ** Node server — **Static Site** لا يعمل، فكل `/api/*` تخدم 200 empty. الواجهة تسقط بأمان إلى demo mode (`FAKE_RESPONSES` + `KernelDemoPill` ثابتة شفاف)، لكن المستخدم الحقيقي **لا يتحدث مع Gemini أبدًا** — يتحدث مع 4 ردود مكتوبة مسبقًا.

تصحيح مهم لفرضية أولية: `output: 'static'` + adapter في Astro 5/6 هو نموذج hybrid صحيح. الكود ليس static-only. المشكلة في **النشر**: خدمة Render مُعدّة كـ Static Site بدل Node web service.

7.2 هـ.1 — chat.astro (الواجهة، 1720 سطر)

البُعد	التقييم	الدليل
الاتصال بـ backend	جاهز	`chat.astro:1104 fetch('/api/ai/chat/', Accept:'text/event-stream')`
streaming SSE	جاهز	`readSSE() :925, consumeSSE() :1226 (response.body.getReader + TextDecoder)`
session management	جيد	`getSessionId() :842, crypto.randomUUID() → sessionStorage`
demo mode	شفّاف لكن افتراضي	`FAKE_RESPONSES :645, runDemoReply() :1213 (setTimeout 700ms), KernelDemoPill pressed:true :125`
error states	ممتازة + عربية	`showChatError() :761 — 6 فئات: rate_limit/provider_failed/network/ unavailable/timeout/unknown`
typing indicator	موجود	`:366 ثلاثي النقاط + aria-busy + sr-only announcer`
onboarding tour	غير موجود	لا tour/walkthrough
first-time UX	مربك	المحادثة تبدأ بـ seed data ثابتة ("تصدير قائمة عملاء محظور") كأنها محادثة مستمرة
mobile (360px)	مدروس	`3-panes تنطوي على drawers تحت 1024px :484-595`

7.3 هـ.2 — chat.ts (الـ backend، 1290 سطر) — جودة إنتاجية

الميزة	الموقع	الحالة (كود)
process.env.GEMINI_API_KEY في runtime	`chat.ts:369`	PASS — تعليق صريح ARCH-2

الميزة	الموقع	الحالة (كود)
streaming SSE	`ReadableStream :860 + sseEvent()`	PASS
fallback Groq→Gemini + circuit breaker	`isProviderOpen :906, recordProviderFailure`	PASS
rate limit per-IP + quota (Redis)	`checkQuota :808`	PASS — fail-closed 503 عند فشل Redis
AI Firewall (PII قبل provider)	`runFirewallSync :739, block→451, approval→428`	PASS
session context (Redis)	`getChatSessionStore().recent() :794`	PASS — degrade to in-memory
البنية التحتية (Redis/Postgres/Sentry)	`src/lib/redis.ts, packages/db (Prisma), packages/lead-queue`	مكتملة في الكود

7.4 هـ.7 — تقييم صفحات kernel الـ 13

الصفحة	سطور	empty	loading	error	?demo	/10
chat	1720	5	2	31	نعم (شفّاف)	8.0
index	670	4	0	1	KernelDemoPill	8.5
scenarios	624	7	1	6	simulated" :458"	7.0
audit	639	1	1	4	drawer	7.0
approvals	680	1	1	2	نعم	6.5
evidence	779	2	1	4	نعم	6.5
policies	575	4	0	1	نعم	6.5
stats	562	0	1	0	mock/stats.json"" :241	5.5
reports	599	0	0	0	نعم (wizard)	5.5
compliance	411	1	0	0	نعم	5.5
connectors	392	0	0	9	static state	5.0
[slug]	183	2	0	0	1	5.0
offline	17	0	0	0	—	6.0

KernelEmptyState + KernelSkeleton موجودان في `src/components/kernel/` لكن **10 من 11 صفحة لا تستخدمهما** — فقط index. الأخطاء الصفرية في stats/connectors/reports = لا مسار "لا توجد بيانات" أصلًا.

7.5 هـ.8 — Mobile 360px (Playwright مباشر على الإنتاج)

نجاح كبير: 0px تجاوز أفقي على 11/11 صفحة

اختبار مباشر عبر Playwright على 11 صفحة kernel بـ hasTouch + isMobile + viewport 360×640. النتائج:

المقياس	النتيجة	الحكم
تجاوز أفقي (overflowX)	0px على كل الصفحات الـ 11	PASS
touch targets ≥ 44px	473/495 (95.6%)	PASS — المخالفة = روابط logo في drawer خارج الشاشة فقط
bottom nav + safe-area	حاضر في KernelLayout	PASS
drawer منزلق صحيح	mobile-menu__header عند right:720px = drawer مخفي، ليس layout bug	PASS

7.6 هـ.9 — RTL correctness

logical properties في **chat (4), evidence (5), scenarios (2), audit/approvals/stats** kernel: **(1 كل)**. physical legacy misuse: **صفر** في تخطيطات الصفحات (الـ margin-left واحد في evidence داخل iframe srcdoc معزول = false positive). RTL 100% نظيف

7.7 هـ.10 — Demo vs Reality (شفافية صادقة)

11 من 13 صفحة تستخدم <KernelDemoPill />. البيانات محاكاة بصراحة: `chat.astro:645 FAKE_RESPONSES`، `stats.astro:241 "Demo datasets matching mock/stats.json"`، `scenarios.astro:458 "Run scenario (simulated)"`. هذا **النموذج الصحيح لـ Demo vs Reality** — صادق، بلا غطاء. لكنه يعني: النظام بأكمله واجهة، لا مسار يتصل بمصدر بيانات حقيقي.

Kernel Scores 7.8

68/100	68/100	82/100	45/100
Kernel Chat	Kernel Pages UX	Kernel Mobile (layout-tier first-class)	Kernel Championship إجمالي (live=0/25)

الحكم النهائي للموبايل

First-class على مستوى التخطيط، afterthought على مستوى المحتوى. البنية التحتية للجوال احترافية (bottom nav ثابت، drawer منطقي، خصائص منطقية، touch ≥44px، 0px overflow). لكن الصفحات ترتاح على التصميم المشترك: لا empty states في 10/11، لا skeleton loading، تحميل متزامن، demo هو الوضع الافتراضي الوحيد المشحون.

8. المرحلة و — التصميم و UX والهوية

الفحص	النتيجة	الحكم
logical properties (RTL-aware)	206 استخدام (inset-inline/margin-inline/padding-inline)	PASS — تحسّن كبير عن v1
physical legacy (margin-left/right)	0 استخدام	PASS
self-hosted fonts (no Google Fonts)	0 مطابقة fonts.googleapis.com في src/	PASS
خطوط woff2 محلية	IBMPlexSansArabic-Regular/SemiBold + Inter-Regular/SemiBold	PASS
brand font subset	TheYearofTheCamel-Medium.subset.woff2 (9.9KB من 58KB)	PASS
line-height عربي (هدف 1.75)	base.css: 1.6 (body), 1.7 (heading), --leading-relaxed 1.75	جزئي — 1.6 body أقل من الموصى
trust badges (SDAIA/NCA/ISO)	ISO 42001×3, ISO 27001×2, NCA×31, SDAIA×13 كنص في /trust/	حاضرة نصًا، لا badges بصرية على hero
viewport + theme-color	viewport-fit=cover, theme-color #060914	PASS
تباين WCAG AA	low-opacity text محدود (rgba 0.3 للظلال فقط)	PASS — تحسّن عن v1 (rgba 0.4 = 3.8:1)

نقاط قوة

RTL نظيف بالكامل (206/0)، خطوط self-hosted بالكامل، brand font subset مُحسّن، تباين محسّن. هذا تقدّم حقيقي عن v1 الذي كان يستخدم physical properties و Google Fonts.

نقاط للمراجعة

line-height body = 1.6 (BAI-DESIGN-04 خفّضه من 1.75) — قد يضر القراءة العربية على نصوص طويلة. trust badges حاضرة كـ text في /trust/ لكن **ليست بصرية على hero** — للبنوك، الـ visual badge على الـ above-the-fold قرار ثقة فوري.

9. المرحلة ز — البنية والكود

الفحص	النتيجة	الحكم
scripts/ folder count (هدف ≥60)	71 ملف (66 .mjs)	+9 فوق الحد
lint:legacy	`echo 'Linting skipped' (no-op)`	وهمي — لكن lint حقيقي عبر pnpm -r
chat.ts size	1290 سطر (20+ دالة في ملف واحد)	monolith قابل للتفكيك
vitest.config	`include: kernel/tests/**` (مسار غير موجود)	config معطّل — vitest يجد 0 ملفات
تطبيق Astro التسويقي (/src)	155 .ts/.tsx، 45 + astro، صفر اختبارات	فجوة تغطية
اختبارات حقيقية	26 ملف في apps/dashboard + /packages/	موجودة للـ dashboard/packages
CI gates	`5 workflows: a11y, ci-build-guard (34KB), deploy, reports-gate, seo-guard, weekly-gsc`	PASS — قوية
Lighthouse CI	`budgets: script≤300KB, total≤1500KB, LCP≤2500ms, INP≤200ms`	PASS — مُفعّل
npm scripts	95 سكربت (verify:all, seo:all,) performance:budget موجودة)	تشفير آلي عالٍ
تبعات محظورة (three/GSAP/...)	0 مطابقات	PASS
React usage	0 (لا @astrojs/react)	PASS — vanilla فقط
TypeScript strict	`extends astro/tsconfigs/strict + strict:true` صريح	PASS
dead code (SparklesHero/HeroVisual)	محذوف — بقيت تعليقان تاريخيان فقط	PASS
Tailwind	محذوف بالكامل	PASS
ci-build-guard.yml	34KB (monolith workflow)	عبء صيانة
lighthouseci/ (git).	~85 95~ ملف، MB (LHR ملتزمة في git؟)	تضخم محتمل

الأدوات الوهمية

`lint:legacy` = echo (وهمي)، `vitest.config include` يشير لـ `kernel/tests/` غير الموجود. الاسم مضلل لكن البديل الحقيقي موجود (`pnpm -r lint` + اختبارات packages).

10. Top 15 قاتل (Killers)

مرتّبة حسب (الأثر × الثقة) ÷ الجهد. CRIT=حرج P0، HIGH=عالي P0/P1، MED=متوسط.

#	القاتل	الفئة	الأثر	الجهد
1	**Render service = Static Site بدل Node** → كل /api/* ميت، Kernel demo وهمي بالكامل	CRIT	10	1h
2	**تسريب مفتاح Gemini القديم** نصًا صريحًا في brain.md:4373 + 3 تقارير + تاريخ git + لقطة شاشة كشفت الجديد	CRIT	10	1h
3	**لا رقم سجل تجاري** في أي مكان — كيان مجهول يبيع للبنوك	CRIT	9	2h
4	**lastmod مكسور** في sitemap (195 entry كلها = تاريخ البناء) → Google يتجاهل freshness	CRIT	8	3h
5	**redirects _redirects غير مُنفّذة** في الإنتاج → /report, /blog/ai → 404	CRIT	8	3h
6	**اسم المؤسس "يزيد" فقط في JSON-LD** + تناقض "الشمري"/"الشريف" في about	HIGH	8	2h
7	**لا صورة مؤسس + لا سيرة مهنية** → ضعف Trust/Authority	HIGH	7	3h
8	**لا /answer/* صفحات** → غياب AEO رغم llms.txt ممتاز	HIGH	7	16h
9	**لا عملاء مسمّين + لا شعارات** → صفر social proof للبنوك	HIGH	7	—
10	**Kernel = demo شفّاف بالكامل** (11/13 صفحة KernelDemoPill، chat=FAKE_RESPONSE (S	HIGH	7	1h (.deploy)
11	**chat.astro seed data مربكة** للمستخدم الأول (محادثة "تصدير عملاء" كأنها حقيقية)	HIGH	6	3h

#	القاتل	الفئة	الأثر	الجهد
12	**لازال CSP unsafe-inline** في inline script 15) (kernel — Phase 2 معلّقة	HIGH	6	24h
13	**/api/* بدون body size limit** (BAI-SEC-20 معلّق)	MED	5	2h
14	**lint:legacy = echo + vitest معطّل** → أدوات وهمية	MED	4	4h
15	**10/11 صفحة kernel بلا empty/skeleton states** → تحميل متزامن يسبب وميض	MED	4	12h

ملحق — تحليل أعمق للقاتلين P0 (الخمسة الأوائل)

القاتل #1 — Render Static Site بدل Node (CRITICAL)

لماذا هذا قاتل المنتج كله

هذا ليس bug عادي — هو **الفرق بين "موقع تسويقي" و "منتج"**. BrightAI مُسوّق على أنه "AI Safety OS" بـ Kernel interactive. في الإنتاج:

- **كل تفاعل** (chat، scenario، policy check) **AI** يخدم empty 200 — الواجهة تسقط لـ FAKE_RESPONSES.
- **كل lead form** يخدم empty 200 — الـ CRM/LeadQueue لا يستقبل شيئًا.
- **كل** 404 → **CSRF token request** — لا حماية CSRF فاعلة.
- Render **health check** نفسه يفشل (404) لكن الخدمة لا تُعاد تشغيلها لأن Static Site لا يفشل هكذا.

الأثر المالي: كل زائر يضغط "جرّب Kernel" أو يملأ lead form → يعتقد الموقع معطّل. لا conversion، لا بيانات عملاء، لا دليل استخدام. هذا يُفسّر إن كان فيه انخفاض في الـ leads منذ إطلاق Kernel.

سهولة الإصلاح: ساعة واحدة على Render dashboard (تغيير نوع الخدمة). لا كود. لا rebuild. الكود مكتمل ومبني في dist/server/entry.mjs. **هذا أرخص إصلاح بأعلى أثر في كامل التدقيق.**

القاتل #2 — مفتاح Gemini مسرّب + لقطة شاشة

ثلاث طبقات تعرّض

1. **الريبو (متعقّب):** AIzaSyC3pLdZ… في 3 + brain.md:4373 تقارير، في git history منذ 3f49dd81. أي شخص ينسخ الريبو العام يرى القيمة.
2. **لقطة الشاشة:** المالك شارك screenshot فيه المفتاح الجديد AIzaSyBFMm… كاملة — **هذا تعرّض لا يعتمد على الريبو**. أي من شاف الـ screenshot عنده القيمة.
3. **المفتاح القديم CONSUMER_SUSPENDED** — يعني Google نفسها علّمت المفتاح كمخالف. لكن القيمة مكشوفة لأي يستخدمها في services أخرى أو لـ impersonation.

الإصلاح الإلزامي (لا مفاوضة): (أ) تدوير كلا المفتاحين من Google AI Studio، (ب) إزالة القيم من الريبو + git filter-repo، (ج) تأكيد المفتاح الجديد على Render فقط، (د) لا screenshots مستقبلًا للمفاتيح.

القاتل #3 — لا رقم سجل تجاري

حاجز البنوك الأول

في سوق B2B سعودي تنفيذي، **أول سؤال من procurement في أي بنك/مستشفى/حكومية: "وش رقم السجل التجاري؟"**. بدونه:

- لا يمكن دخول vendor registration في أي جهة حكومية أو بنك.
- لا يمكن فتح vendor file في SAMA-regulated entities.
- Google Knowledge Graph لن يبني كيان BrightAI (يحتاج إثبات legal entity).
- Google Business Profile لا يُفعّل بدون CR مرتبط بالعنوان.

الإصلاح: 2 ساعة (بعد ما المالك يعطي الرقم). أثر: +8 نقاط Saudi Championship + يفتح باب vendor registrations.

[ASSUMPTION — confidence 50%]: إن لم يوجد CR فعليًا بعد، هذا إشارة إن BrightAI في مرحلة ما قبل التسجيل القانوني — يجب تأكيده مع المالك قبل ادعاء رقم.

القاتل #4 — lastmod مكسور في sitemap

contradction موثّقة = Google يتجاهل

هذا finding خفي لكنه مؤذي. الـ contract في الكود (generate-sitemap-all-pages.mjs:21-29) يقول صراحةً إن lastmod يُشتق من git log. المحلي صحيح (9 تواريخ). لكن الإنتاج يخدم 195 entry كلها = تاريخ البناء.

عواقب SEO:

- Google يرى كل الصفحات "تحديثت اليوم" يوميًا → يصير متشككًا → **يتجاهل lastmod كليًا** → يعتمد على crawl rate فقط.
- الصفحات التي فعلًا تحدّثت (blog جديد) لا تحصل على أولوية إعادة الزحف.
- PageRank freshness signal يُضعف.

الإصلاح: 3 ساعات — تحقيق أين يُعاد كتابة lastmod في pipeline الإنتاج (محتمل astro sitemap integration أو Render build step) + إصلاحه.

القاتل #5 — redirects _redirects غير مُنفّذة

روابط مكسورة + link juice مهدور

public/_redirects فيه 216 سطر، 134 قاعدة. لكن الإنتاج يطبّق فقط trailing-slash normalization ويتجاهل الـ dest المخصصة.

الـ rule في _redirects	ما يحدث فعليًا	النتيجة
`/report → /trust/ 301`	`/report → /report/ → 404`	link broken
`/blog/ai → /404/ 301`	`/blog/ai → /blog/ai/ → 404`	link broken
`/blog/Generative-artificial-intelligence → ...`	`→ /blog/Generative.../ → 404`	link broken
`/blog.html`	`404 مباشر (لا rule عام .html)`	link broken

الأثر: (أ) أي backlink خارجي يشير لهذه الـ 404 → legacy URLs → يخسر link juice. (ب) UX سيء لمن يصل من روابط قديمة. (ج) 14% من الزيارات في v1 كانت 404 (GA4) — قد تكون هذه السبب.

الإصلاح: 3 ساعات — إمّا تفعيل _redirects على Render (يتطلب middleware) أو نقل القواعد لـ Cloudflare Transform Rules أو astro.config redirects (الذي يعمل confirmed).

لماذا هذه الخمسة تحديدًا P0؟

معيار P0: (الأثر × الثقة) ÷ الجهد عالٍ + قابل للإصلاح في 48h

الخمسة كلها: (أ) تحجب الوظيفة الأساسية أو الثقة، (ب) تشخيصها مؤكد بـ curl (ثقة ≥90%)، (ج) إصلاحها ≥ 3 ساعات لكل واحد. إصلاحها معًا (~12 ساعة عمل + نشر) يرفع الإنتاج من 47.5% إلى ~65%. **هذه أعلى ROI في كامل التدقيق.**

11. خارطة الطريق: Saudi + Kernel Championship (90 يومًا)

11.1 Saudi Championship Roadmap — للوصول لـ SERP top 3

الأسبوع	الإجراء	الكلمة/المحور	الأثر المتوقع
1	إضافة رقم السجل التجاري في footer + JSON-LD + llms.txt	كيان قانوني	8+
1	توحيد "يزيد الشريف" في كل JSON-LD + إزالة "الشمري" + صورة احترافية + سيرة	E-E-A-T	6+
2-3	إنشاء 10 صفحات /answer/* بـ FAQPage + Speakable لكل Target Query في llms.txt	AEO	7+
3-4	أول عميل مرجعي مسمّى + شعار + badge "aligned with SAMA/SDAIA/NCA"	Trust بنوك	5+
4-6	عناقيد مواضيعية: PDPL (8 مقالات + pillar) + ISO 42001 (8) + ECC (8)	كلمات عالية الطلب	6+
6-8	Google Business Profile + press release (الاقتصادية/عكاظ) + LinkedIn thought leadership	Authority + Local	4+
8-12	شراكات جامعية (KSU/KFUPM/KAU) + حضور LEAP 2026 + Black Hat MEA	Authority إقليمي	3+

الإجمالي المتوقع: 56 → 88/100 → موضع ترشيح قوي لـ #1 في 90 يومًا.

11.2 Kernel Championship Roadmap — لتحويل /kernel/ لمنتج حقيقي

المرحلة	الإجراء	التحقق	الأثر
P0 — حاجب	إعادة نشر Render كـ Node web service (`node ./dist/server/entry.mjs`) بدل Static Site	`curl -I /api/health/` → JSON + `x-brightai-build` header	(live) 25+
P0	ضبط env على Render: GEMINI_API_KEY, GROQ_API_KEY, REDIS_URL, DATABASE_URL, BRIGHTAI_CHAT_KEY, CHAT_STREAMING_ENABLED	`POST /api/ai/chat/` → reply حقيقي من Gemini	unblocks

المرحلة	الإجراء	التحقق	الأثر
P0	تشغيل pnpm run verify:post- deploy بعد النشر	مطابقة build هوية + exit 0 git HEAD	تطابق
P1	تفعيل x-brightai-build كـ health signal + alert عند غيابه	uptime monitor	رصد
P1	إزالة seed data من chat + إضافة onboarding للمستخدم الأول	UX	3+
P2	اختبار firewall حي: ? scenario=pdpl-id-leak → HTTP 451	curl ... → 451	إثبات
P2	empty states + skeleton loading لـ 10 صفحات kernel	UX	5+
P3	توصيل audit/approvals/evidence بـ backend حقيقي (لا demo)	multi-day	10+

الخلاصة: 90% من العمل منجز؛ المتبقي **قرار نشر واحد** على Render (ساعة) + ضبط env. بعدها يصير Kernel منتجًا حقيقيًا متصلًا بـ Gemini.

11.3 Mobile Championship Checklist (كل صفحة kernel × 360px)

الإصلاح	الموقع	الأولوية
min-height:44px على روابط logo في mobile- menu__header (24px حاليًا)	KernelLayout.astro	P1
إضافة KernelEmptyState لـ 10/11 صفحة	src/pages/kernel/* (استيراد موجود)	P1
إضافة KernelSkeleton (تحميل غير متزامن)	src/pages/kernel/* (موجود، غير مستخدم)	P1
role="img" aria-label= + alt= لكل صورة/SVG في kernel	src/pages/kernel/* (alt=0 عبر الكل)	P2
aria-live + retry UI على connectors (9 إشارة خطأ بلا مسار)	connectors.astro:246	P2
landmark roles + labels على offline.astro (HTML مهاجَر بلا a11y)	offline.astro	P2
نقل CSP directives من meta إلى HTTP headers (4 أخطاء console لكل صفحة)	astro.config + Edge	P2

12. خطة Gemini API Integration

الحالة الحالية: الكود جاهز + مكتمل

chat.ts يقرأ process.env.GEMINI_API_KEY في runtime (line 369)، يستخدم gemini-2.5-flash (line 373)، streaming SSE حقيقي، Gemini→Groq fallback مع AI Firewall، circuit breaker قبل أي quota Redis multi-dim، provider. **كل مكون إنتاجي.**

12.1 سلسلة التحقق (كلها فاشلة حاليًا — ستتحول PASS بعد النشر)

```
# 1. health (يجب أن يرجع JSON، ليس HTML 404)
curl -i https://brightai.site/api/health/
# 200 :المتوقع بعد النشر + {"status":"ok"} + x-brightai-build: <sha>

# 2. chat (يجب أن يرجع reply من Gemini)
curl -i -X POST https://brightai.site/api/ai/chat/ \
  -H "Origin: https://brightai.site" \
  -H "Content-Type: application/json" \
  -d '{"message":"مرحبا، ما هي BrightAI؟"}'
# 200 :المتوقع + {"reply":"...","provider":"gemini"}

# 3. streaming SSE
curl -N -X POST https://brightai.site/api/ai/chat/ \
  -H "Origin: https://brightai.site" \
  -H "Accept: text/event-stream" \
  -H "Content-Type: application/json" \
  -d '{"message":"اشرح PDPL"}'
# المتوقع: event: token data: {...} متعددة

# 4. firewall (PII → 451)
curl -i -X POST https://brightai.site/api/ai/chat/ \
  -H "Origin: https://brightai.site" -H "Content-Type: application/json" \
  -d '{"message":"1234567890 رقم هويتي"}'
# 451 :المتوقع (block من K3 firewall قبل Gemini)

# 5. CSRF على lead
curl -i -X POST https://brightai.site/api/lead/ \
  -H "Origin: https://brightai.site" -H "Content-Type: application/json" \
  -d '{"name":"test","contact":"t@t.com"}'
# 200 :المتوقع + JSON صريح (وليس silent empty)
```

12.2 ملاحظة أمنية حرجة

تدوير مفتاح Gemini إجباري

لقطة شاشة المالك كشفت GEMINI_API_KEY = AIzaSyBFMm... كاملة. حتى لو لم تظهر في الريبو (مؤكد: نظيف)، **يجب تدويرها فوراً من Google AI Studio**. أي قيمة عُرضت في screenshot تُعتبر مُخترَقة. كذلك المفتاح القديم AIzaSyC3pLdZ... يجب: (أ) إزالته من brain.md:4373 + 3 تقارير، (ب) git filter-repo لتنظيف التاريخ إن أمكن، (ج) تأكيد CONSUMER_SUSPENDED دائم.

13. خرائط P0/P1/P2/P3 + المخاطر + ما يجب ألا يُلمس

13.1 خريطة الأولويات

المستوى	الإطار الزمني	الفئة	أمثلة
P0	48 ساعة	deploy + secure + Gemini live	إعادة نشر Render، تدوير مفتاح، سجل تجاري، إصلاح lastmod + redirects
P1	أسبوعان	Saudi content + kernel real + UX	اسم مؤسس كامل، answer/*، empty/ states، onboarding chat، CSP Phase 2
P2	شهر	mobile championship + AEO depth	عناقيد badge، PDPL/ECC بنوك، ROI link، touch targets، alt/a11y
P3	3-6 أشهر	SERP top 3 + backlinks + #1	press releases، شراكات جامعية، LEAP/Black Hat، توصيل kernel بـ backend حقيقي

13.2 المخاطر

مخاطر تشغيلية

- **النشر كـ Node قد يكسر static behavior** الحالي (195 صفحة تعمل). الخطة: النشر التدريجي أو static + SSR مختلط مع monitor.
- **lastmod fix قد يبطّئ إعادة الزحف مؤقتًا** لو Google اعتبر التواريخ القديمة "أقل حداثة". خطر منخفض.
- **تدوير المفتاح يكسر محليًا** لو .env ما حدّث. توثيق في .env.example.

مخاطر تسويقية

- **"الشمري" vs "الشريف"** — يجب تأكيد الاسم القانوني الصحيح قبل التوحيد.
- **سجل تجاري** إن لم يوجد فعليًا، ادعاء رقم = مخالفة قانونية. التأكيد مع المالك قبل النشر.
- **"aligned with" badge** لا "certified by" — الادعاء الخاطئ للشهادات مخالفة SDAIA.

13.3 ما يجب ألا يُلمس (Do Not Touch)

الأصل	السبب
النص العربي المنشور (titles, h1-h6, meta description)	مُفهرَس في Google + اللهجة السعودية مقصودة
section 16 في الرئيسية	ترتيب + عدد مقدّس
'astro.config.mjs trailingSlash:'always	314 redirect + آلاف الروابط تعتمد عليه
*public/_redirects, _headers, robots.txt, sitemap	ملفات محمية
src/data/site.ts, navigation.ts, i18n-pairs.ts	تأثير على كل الصفحات
قيم JSON-LD المنشورة	مُفهرَسة — لا تغيير بدون موافقة

الأصل	السبب
**/frontend (backend Express منفصل)	خدمة منفصلة، لا نشر كـ static

13.4 فجوات البيانات [DATA GAP] + افتراضات [ASSUMPTION]

النوع	البند	الثقة
DATA GAP	GSC — كم صفحة مفهرسة؟ (الهدف 50+ من 195)	—
DATA GAP	Google Business Profile — موجود للعنوان؟	—
DATA GAP	GA4 — source/medium، conversion، real SA traffic	—
ASSUMPTION	ذكر BrightAI في ChatGPT/Perplexity	30%
ASSUMPTION	SERP positions (WebSearch يوليو 2026 قد تتغير)	70%
ASSUMPTION	Render service type (Static vs Node — استنتاج من rndr-id header)	85%

ملحق — ترتيب التنفيذ (Batches 1→5)

البرومبتات الكاملة في brightai-audit-reports/brightai-audit-prompts-v3.md. الترتيب تسلسلي: ما أبدأ batch قبل ما خلص اللي قبله + أتحقق.

Batch 1 — 48 ساعة (deploy + secure + Gemini live)

الهدف: رفع الإنتاج من 47.5% إلى ~65% + تفعيل Kernel product.

ID	البرومبت	الأثر
BAI-DEPLOY-13	إعادة نشر Render كـ Node Web Service	10
BAI-SEC-13	تدوير مفتاح Gemini + إزالة من brain.md	10
BAI-DEPLOY-14	ضبط env vars على Render + verify:post-deploy	8
BAI-DEPLOY-15	Cloudflare cache purge تلقائي بعد deploy	6
BAI-SEC-16	api/lead/ يرجع JSON صريح (PDPL مادة 16)	7
BAI-IDX-13	إصلاح lastmod per-page في sitemap الإنتاجي	8
BAI-IDX-16	تفعيل _redirects على Render (Cloudflare Transform)	7
BAI-SAID-01	رقم السجل التجاري في footer + JSON-LD + llms.txt	9
BAI-SAID-02	توحيد اسم المؤسس "يزيد الشريف" + صورة + سيرة	8

تحقق Batch 1

- curl /api/health/ → JSON
- POST /api/ai/chat/ → reply حقيقي من Gemini
- x-brightai-build header حاضر
- grep -rn "AIzaSy" .agents/ report/ → 0
- sitemap lastmod فريدة ≤ 5
- CR في footer + JSON-LD

Batch 2 — أسبوعان (Saudi content + kernel real)

الهدف: 65% → 72% + كسر حاجز الـ demo + بداية احتلال SERP.

ID	البرومبت	الأثر
BAI-KERNEL-01	إزالة seed data من onboarding + chat للمستخدم الأول	7
BAI-KERNEL-02	empty states + skeleton لـ 10/11 صفحة kernel	6
BAI-KERNEL-03	اختبار firewall حي: ?scenario=pdpl-id-leak → 451	5

ID	البرومبت	الأثر
BAI-SAID-03	10 صفحات /answer/* بـ FAQPage + Speakable	8
BAI-SAID-04	5 صفحات /lp/* تجارية (PDPL/ECC/banking/health/gov)	7
BAI-SAID-05	عنقود SDAIA (8 مقالات + pillar)	6
BAI-SAID-06	عنقود PDPL (8 مقالات + pillar متعمق)	6
BAI-SEC-18	CSP Phase 2: nonce-based (15 kernel inline script)	6
BAI-SEC-20	api/* (10KB chat, 5KB/ على body size limit lead)	5
BAI-DESIGN-06	trust badges بصرية على hero (aligned with)	6

Batch 3 — شهر (mobile championship + AEO depth)

الهدف: 72% → 78% + mobile first-class على content-tier.

ID	البرومبت	الأثر
BAI-MOBILE-01	min-height:44px على روابط logo (KernelLayout)	4
BAI-MOBILE-02	role="img" aria-label= + alt= لكل صورة kernel	4
BAI-MOBILE-03	retry UI + aria-live على connectors	3
BAI-MOBILE-04	PWA manifest + service worker لـ /kernel/	5
BAI-A11Y-01	landmark roles + labels على offline.astro	3
BAI-A11Y-02	focus-visible على كل interactive kernel	4
BAI-SAID-07	عنقود ECC (8 مقالات) + ISO 42001 (8)	6
BAI-SAID-08	أول عميل مرجعي مسمّى + شعار في /customers/bank/	7
BAI-PERF-02	Lighthouse CI gate live (LCP ≤ 2500ms)	5

Batch 4 — 3 أشهر (SERP top 3 + backlinks)

الهدف: 78% → 84% + احتلال كلمات الطلب العالي.

ID	البرومبت	الأثر
BAI-SAID-09	Google Business Profile موثّق + NAP موحّد	5
BAI-GROWTH-01	press release (الاقتصادية/عكاظ/الرياض)	6
BAI-GROWTH-02	LinkedIn thought leadership (8 مقالات مؤسس)	5
BAI-GROWTH-03	شهادات G2/Capterra/Clutch	5

ID	البرومبت	الأثر
BAI-MEAS-01	GA4 events (chat_started/completed/lead)	4
BAI-ARCH-01	تفكيك chat.ts (300≤ ← 1290 لكل module)	4
BAI-ARCH-02	إصلاح vitest.config + lint:legacy حقيقي	3
BAI-ARCH-03	تنظيف scripts/ (71 → ≤60)	3

Batch 5 — 6 أشهر (#1 في KSA + العالم العربي)

الهدف: 84% → 88% + بطولة إقليمية + Kernel منتج حقيقي متكامل.

ID	البرومبت	الأثر
BAI-SAID-10	شراكات جامعية (KSU/KFUPM/KAU)	4
BAI-SAID-11	حضور LEAP 2026 + Black Hat MEA	4
BAI-KERNEL-04	توصيل audit/approvals بـ backend حقيقي (لا demo)	8
BAI-KERNEL-05	evidence file generation (PDF موقّع حقيقي)	6
BAI-KERNEL-06	real-time collaboration (WebRTC/WebSocket)	5
BAI-MOBILE-05	app-like navigation على bottom tab bar) mobile)	4
BAI-KERNEL-07	Arabic voice input (Web Speech API) في chat	4
BAI-KERNEL-08	export to PDF/CSV لكل dashboard	4
BAI-GROWTH-04	backlinks من 20 موقع سعودي موثوق	6

منحنى النمو المتوقع (v3 → نهاية Batch 5)

v3 الحالي **47.5%** → Batch 5 **~88%** → Batch 4 **~84%** → Batch 3 **~78%** → Batch 2 **~72%** → Batch 1 **~65%**. السقف الواقعي 85-90% (باقي الـ 10-15% = محتوى مستمر + backlinks + بيانات GSC حقيقية).

ملحق هـ — تشخيص تفصيلي لصفحات Kernel

تقييم كل صفحة kernel على محاور UX الستة (first-time experience، empty state، loading، error، mobile، a11y). الدرجة من 10.

هـ.1 chat.astro — 8.0/10 (الأفضل)

1720 سطر · قلب المنتج

القوة: SSE reader مكتوب يدويًا (response.body.getReader + TextDecoder) يتعامل صحيحًا مع POST streaming (EventSource يدعم GET فقط). معالجة أخطاء عربية شاملة في 6 فئات مع typing indicator. tone (info/warning/danger) ثلاثي النقاط + sr- + aria-busy only announcer للـ 3-panes AT. تنطوي على drawers منزلقة تحت 1024px مع toolbar زرّين.

الضعف: تبدأ بـ seed data ثابتة ("تصدير قائمة عملاء محظور") كأنها محادثة مستمرة — يُربك المستخدم الأول الذي يظنها محادثته. لا onboarding tour. demo mode افتراضي (KernelDemoPill pressed=true).

السطر الحاسم: 4 — `chat.astro:645 FAKE_RESPONSES = [...]` ردود مكتوبة مسبقًا هي ما يراه المستخدم الحقيقي (لأن Node server لا يعمل).

هـ.2 index.astro — 8.5/10

الصفحة الوحيدة التي تستخدم KernelEmptyState + KernelSkeleton (4 empty state signals، 3 media queries، min-h 44px). landing واضح. لكن KernelDemoPill حاضر = demo هو الافتراضي.

هـ.3 audit.astro — 7.0/10

drawer للتنقّل + نسخ/تصدير. 4 إشارات خطأ. لكن 7 demo signals (drawer copy/export محاكاة). لا media query خاصة (يعتمد على kernel.css المشترك).

هـ.4 approvals.astro — 6.5/10

human approval layer. 2 error signals، 4 demo setTimeout. لا empty state حقيقي. يعتمد كليًا على التصميم المشترك للجوال.

هـ.5 evidence.astro — 6.5/10

779 سطر (الأطول بعد chat). iframe srcdoc لمعاينة ملف evidence (هنا margin-left:8px لكن داخل iframe معزول = false positive). 4 error signals، 2 empty، 2 demo.

هـ.6 policies.astro — 6.5/10

policy editor. 4 empty state signals (الأفضل بعد index). لكن 0 (2 setTimeout) loading. demo mode.

هـ.7 scenarios.astro — 7.0/10

risk scenarios. 7 empty (الأعلى). "Run scenario (simulated)" في السطر 458 — صريح بصراحة عن كونه 2 ،error signals 6 .demo media queries.

هـ.8 stats.astro — 5.5/10

0 empty state. dashboard. التعليق الصريح في السطر 241: "Demo datasets matching kernel/api/mock/stats.json structure" — يعترف بصراحة أن البيانات 0 error signals .mock.

هـ.9 connectors.astro — 5.0/10 (الأضعف)

392 سطر. **9 إشارات خطأ بدون مسار UI لإعادة المحاولة** (connector-card__error على L246). static. 0 demo، 0 loading، 0 empty state فقط. الأضعف بين صفحات kernel.

هـ.10 reports.astro — 5.5/10

wizard لإنشاء تقارير امتثال. 0 setTimeout demo 3 error. 0، empty. يعتمد على mock data.

هـ.11 compliance.astro — 5.5/10

compliance packs. 1 empty، 0 error، 1 demo. ثابت.

هـ.12 [slug].astro — 5.0/10

183 dynamic handler. سطر فقط. 3 aria فقط (ضعيف). بنية ضعيفة. يستقبل HTML مهاجِر من جهة خارجية.

هـ.13 offline.astro — 6.0/10

17 سطر فقط (SW fallback). {DOMPurify.sanitize(...)} — <main set:html= /> يحقن HTML مهاجَر بدون معلومات وصول قابلة للتخطيط. خطر متوسط. **0 aria / 0 alt**

هـ.14 مشاكل mobile الثمانية (بالأدلة)

#	المشكلة	الصفحة	الإصلاح المحدد
1	logo + "الرئيسية" (target = 24px ≥44)	`KernelLayout.astro mobile-menu__header`	min-height:44px على رابط logo
2	لا empty state في 10/11 صفحة	`stats/connectors/reports/compliance/policies/evidence/approvals/audit/offline/[slug]`	استيراد <KernelEmptyState /> (موجود)
3	لا skeleton loading في 10/11	`نفس القائمة`	استيراد <KernelSkeleton /> أثناء انتظار JS data
4	offline.astro = HTML مهاجَر بلا a11y	`offline.astro`	لف في <main aria-label="...">
5	alt= 0 عبر كل kernel الـ 13	`src/pages/kernel/*`	alt على <picture>؛ role="img" aria-label على SVG
6	connectors 9 error بلا retry UI	`connectors.astro:246`	retry button + aria-live على connector-card__error
7	"stats "mock/stats.json بدون toggle	`stats.astro:241`	إما توصيل /api/kernel/stats أو KernelEmptyState عند غياب demo
8	4 أخطاء CSP meta-tag لكل صفحة	`كل kernel`	frame-ancestors/report-uri/X-Frame → HTTP headers لا meta

هـ.15 حكم الموبايل النهائي

Layout-tier first-class (82/100)

0px تجاوز أفقي على 11/11 صفحة (مؤكد بـ Playwright مباشر على الإنتاج). 95.6% bottom nav .touch targets ≥44px ثابت + safe-area inset + drawer منطقي + خصائص منطقية + قائمة سفلية قابلة للتمرير (overflow-x:auto تتعامل مع 11 رابط). **هذا نادر ومستحق.**

Content-tier afterthought

الصفحات ترتاح على التصميم المشترك: لا empty states في 10/11، لا skeleton، تحميل متزامن يسبب وميض، demo هو الوضع الافتراضي الوحيد المشحون. الصفحات النشطة (index/audit/chat/scenarios) ممتازة؛ الذيل الطويل ([slug]/connectors/stats/compliance/reports) يشبه ما بعد الإطلاق.

ملحق د — المنافسة السعودية + استراتيجية الكلمات

د.1 المنافسون بالتفصيل

SDAIA (sdaia.gov.sa + dgp.sdaia.gov.sa)

الجهة الحكومية المنظّمة. تملك "منصة حوكمة البيانات الوطنية" + السجل الوطني لمقدمي خدمات البيانات. حصلت على ISO 42001 ذاتيًا (يوليو 2024). **ليست أداة حوكمة AI تشغيلية للشركات** — لا AI Firewall، لا Human Approval layer. أصدرت 48 قرار مخالفة = طلب حقيقي في السوق.

علاقة: BrightAI = الطبقة التشغيلية التي تنظّمها SDAIA

NCA (nca.gov.sa)

يملك ECC-2:2024 Assessment and Compliance Tool رسمية (Excel/dashboard تقييم ذاتي). **أداة تقييم امتثال سيبراني عامة، ليست حوكمة AI** — لا تتعامل مع نماذج/مخرجات AI. علاقة: BrightAI = Policy-to-Control Mapping يربط سياسات الشركة بضوابط ECC

PwC Saudi / ME

تقرير "Saudi AI Maturity"، إطار Responsible AI (4-6 أسابيع)، AI Managed Services. **خدمة استشارية فقط — لا منصة منتج SaaS، سعر عالٍ، دورة بيع طويلة.** علاقة: BrightAI = منتج تشغيلي مستمر لا مشروع محدود

KPMG Saudi

صفحة PDPL سعودية + (حسب LinkedIn) منصة تتضمن "AI Security & Governance" مع PDPL/ADHICS. **غالبًا عرض استشاري/تقريري، ليس منتج مستقل قابل للشراء.**

EY / Deloitte Saudi

أطر Responsible/Trustworthy AI عالمية، شراكة Microsoft، تعليق Deloitte ME عن تبني GenAI في السعودية. **لا صفحة سعودية مخصصة لحوكمة AI**؛ صفحاتها Global/MENA عامة.

bright.ai (الشركة الأمريكية)

تمويل جيد، منصة Physical AI للبنية التحتية الحساسة (IoT/edge/foundation models). **مجال مختلف تمامًا (بنية تحتية فيزيائية وليس حوكمة AI مؤسسية)، لا حضور سعودي واضح.** خطر ارتباك علامة محدود فقط بسبب تشابه الاسم.

OneTrust / Securiti.ai / BigID / Legit

منتجات GRC/privacy ناضجة تستهدف PDPL السعودي. **تركيز privacy/PDPL وليس AI governance؛ غربية، تكييف محلي محدود.**

DataMost AI / Asas.ai / Sahl

منتجات امتثال PDPL سعودية محلية. Asas.ai عندها PDPL Compliance Checker مجاني. **PDPL فقط، لا AI governance.** منافسون على كلمة "PDPL".

ريناد المجد RMG (rmg-sa.com)

شركة سعودية محلية تقدم خدمات SAMA Cybersecurity Framework + ISO 42001 + حوكمة AI. **أقرب منافس سعودي محلي — لكنه خدمات استشارية/تدقيق ليست منصة منتج.**

SCube / CyberArrow / CYBR / Jethur

أدوات امتثال ECC-2:2024 (قوالب، dashboards، أتمتة). **ECC فقط، لا AI governance.**

د.2 استراتيجية الكلمات — البطولات الحقيقية

بطولة #1 مكتسبة (للدفاع)

- **"حوكمة الذكاء الاصطناعي السعودية"** — BrightAI يظهر كأول نتيجة في WebSearch. متصدر فعليًا
- **"جدار حماية الذكاء الاصطناعي" / "AI Firewall السعودية"** — BrightAI النتيجة الوحيدة المرتجعة. مصطلح ناشئ بدون منافسة = فرصة احتكار + تعريف المصطلح في المعجم السعودي.

كلمات الطلب العالي — غياب كامل

- **"نظام حماية البيانات الشخصية" (PDPL)** — SDAIA + DataMost + Resecurity تتصدّر. BrightAI غائب عن أول 10. طلب تجاري ضخم.
- **"ضوابط ECC"** — مكتظة بـ NCA + CYBR + CyberArrow + Jethur.
- **"حوكمة AI للبنوك" / "SAMA AI"** — SAMA Rulebook + RMG + evc.sa. BrightAI غائب رغم وجود /solutions/banking-ai-governance/. مشكلة فهرسة/سلطة لا غياب محتوى.
- **"ISO 42001 السعودية"** — مكتظة بمن يبيع الشهادة/التدريب (SCube + RMG + Vinsys).

د.3 الفجوة بين الصفحات الموجودة و SERP

/solutions/banking-ai-governance/ و /solutions/policy-to-control-mapping/ موجودة لكن **لا تظهر في SERP** لكلماتها المستهدفة.

التشخيص: (أ) صفر backlinks، (ب) صفر internal linking من pillar pages، (ج) محتوى قد يكون أقصر من منافسي SDAIA/Big 4. الحل: pillar pages (1500+ كلمة) + internal mesh + cluster articles.

ملحق — معاينة برومبتات v3 (الكاملة في ملف Markdown منفصل)

الملف الكامل: brightai-audit-reports/brightai-audit-prompts-v3.md (60-100 برومبت). هنا معاينة أهم 5 برومبتات P0 بالقالب الإلزامي.

BAI-DEPLOY-13 — إعادة نشر Render كـ Node Web Service

```
## PROMPT [ID: BAI-DEPLOY-13] — إعادة نشر Render كـ Node Web Service
**Priority: P0 · Effort: 1h · Impact: 10 · Risk: medium · Depends: none · Blocks: BAI-KERNEL-01**

**CONTEXT** — خدمة brightai-site المنشورة على Render كـ Static Site بدل Node web service، مُعدّة كـ runtime:node + startCommand: node ./dist/server/entry.mjs. النتيجة: رغم أن render.yaml:11-15 يصف GET. هيدر x-rndr-id (بصمة Static Site) حاضر، وغياب /api/* تخدم empty 200 على POST و 404 على chat.ts. مكتمل ومبني Node server لا يعمل. يؤكد أن entry.mjs (الذي يُحقنه brightai-build) يحوي 3 مراجع لمسار chat) لكنه لا يُنفّذ. (dist/server/entry.mjs

**FILES IN SCOPE**
- render.yaml:11-15 (runtime/startCommand/healthCheckPath)
- Render dashboard (إعداد الخدمة — خارج الريبو)
- astro.config.mjs:182-189,230 (output:static + adapter node standalone)

**MUST NOT TOUCH / PRESERVE**
- src/pages/api/** (الكود سليم، لا تعديل)
- dist/server/** (مبني صحيح)
- trailingSlash:'always' (مقدّس)

**TASK**
1. في Render dashboard، افتح خدمة brightai-site.
2. غيّر نوع الخدمة من "Static Site" إلى "Web Service" مع runtime Node 22.
3. تأكد أن startCommand = `node ./dist/server/entry.mjs` (يطابق render.yaml:15).
4. تأكد أن healthCheckPath = `/api/health/` (render.yaml:15).
5. أضف env vars: GEMINI_API_KEY (مُدوَّر)، GROQ_API_KEY، REDIS_URL (rediss://)، DATABASE_URL، BRIGHTAI_CHAT_KEY، CHAT_STREAMING_ENABLED=true.
6. Deploy + انتظر health check.

**ACCEPTANCE CRITERIA** (على الإنتاج curl واحد على الأقل)
- `curl -i https://brightai.site/api/health/` → 200 + JSON `{"status":"ok"}` + هيدر `x-brightai-build: <sha>`
- `curl -i -X POST https://brightai.site/api/ai/chat/ -H "Origin: https://brightai.site" -H "Content-Type: application/json" -d '{"message":"مرحبا"}'` → 200 + `{"reply":"...","provider":"gemini"}` (وليس empty)

**VERIFICATION COMMANDS**
```bash
curl -sI https://brightai.site/api/health/ | grep -iE "http|x-brightai-build"
curl -s -X POST https://brightai.site/api/ai/chat/ -H "Origin: https://brightai.site" -H "Content-Type: application/json" -d '{"message":"test"}' | head -c 200
pnpm run verify:post-deploy
```

ROLLBACK — في Render dashboard، عُدّ للنشر السابق (Static Site). الكود غير متأثر لأن التعديل إعداد نشر فقط.

DEFINITION OF DONE — /api/health/ يرجع JSON، /api/ai/chat/ يرجع reply حقيقي من Gemini، x-
```

```
brightai-build header حاضر في كل رد /api/*.
---
```

BAI-SEC-13 — تدوير مفتاح Gemini + إزالته من brain.md

```
## PROMPT [ID: BAI-SEC-13] — تدوير مفتاح Gemini + تنظيف brain.md
**Priority: P0 · Effort: 1h · Impact: 10 · Risk: low · Depends: none · Blocks: BAI-KERNEL-01**

**CONTEXT** — المفتاح القديم AIzaSyC3pLdZ-7R2XlvPFTZ8Alg93zkuThHbQYM لا يزال نصًا صريحًا في
.agents/brain.md:4373 + 3 تقارير (report/A/2026-07-15-kernel-audit-master.md:119, report/A/2026-
07-18-pre-audit-brain-snapshot.md:1320, brightai-audit-reports/prompt/brightai-audit-
prompts.md:289) — كلها متتبّعة في git (دخل عبر commits 3f49dd81 و55 b6464c، في HEAD a8857c26).
لكن تعرّضه النصّي باقٍ. لقطة شاشة المالك كشفت المفتاح الجديد عند Google CONSUMER_SUSPENDED المفتاح
AIzaSyBFMm… كاملة → يجب تدويره أيضًا بغض النظر عن الريبو.

**FILES IN SCOPE**
- .agents/brain.md:4373
- report/A/2026-07-15-kernel-audit-master.md:119
- report/A/2026-07-18-pre-audit-brain-snapshot.md:1320
- brightai-audit-reports/prompt/brightai-audit-prompts.md:289
- Google AI Studio (تدوير خارج الريبو)
- Render dashboard env (تحديث GEMINI_API_KEY)

**MUST NOT TOUCH / PRESERVE**
- src/pages/api/ai/chat.ts (يقرأ process.env، لا تغيير)
- .env (gitignored، تحديث محلي فقط)

**TASK**
1. في Google AI Studio، أنشئ مفتاح Gemini جديد. عطّل/احذف المفتاحين القديم والجديد المسرّب.
2. حدّث GEMINI_API_KEY على Render dashboard (النشر القادم يلتقطه).
3. استبدل القيمة النصية في brain.md:4373 بـ `process.env.GEMINI_API_KEY (rotated 2026-07-29)`.
4. كرّر للملفات الـ 3 الأخرى (استبدل القيمة بمرجع env).
5. commit + push.
6. (اختياري لكن موصى) git filter-repo لتنظيف القيمة من التاريخ الكامل.

**ACCEPTANCE CRITERIA**
- `grep -rn "AIzaSy" . --include="*.md" --include="*.ts" 2>/dev/null | grep -v node_modules` → 0 نتائج
- `git log --all -S "AIzaSyC3pLdZ" --oneline` → 0 أو مرجع إما فقط env

**VERIFICATION COMMANDS**
```bash
grep -rn "AIzaSy" .agents/ report/ brightai-audit-reports/ 2>/dev/null | grep -v node_modules
git log --all -S "AIzaSyC3pLdZ" --oneline | head
```

ROLLBACK — لا rollback (الأمان: القيمة المسروقة لا يجب أن تعود). إذا كسر التطبيق، حدّث
GEMINI_API_KEY على Render بالمفتاح الجديد.

DEFINITION OF DONE — صفر قيم AIzaSy في الريبو + المفتاح مُدوَّر في Google + محدّث في Render.

```

BAI-SAID-01 — رقم السجل التجاري في footer + JSON-LD + llms.txt

```
## PROMPT [ID: BAI-SAID-01] — إضافة رقم السجل التجاري (كيان قانوني)
**Priority: P0 · Effort: 2h · Impact: 9 · Risk: low · Depends: user-provides-CR · Blocks: BAI-SAID-04**

**CONTEXT** — صفر ذكر لرقم سجل تجاري عبر كل الصفحات + JSON-LD + llms.txt. في سوق B2B سعودي تنفيذي (بنوك/مستشفيات)، غياب إثبات الكيان القانوني = حاجز ثقة حرج. JSON-LD Organization.founder.name = "بزيد" فقط (اسم أول) يزيد الكيان مجهولية.

**FILES IN SCOPE**
- src/components/Footer.astro (إضافة CR في footer كل الصفحات)
- src/data/site.ts (إضافة crNumber field)
- src/data/schema-saudi-seo.json + أي schema generator (إضافة taxID/identifier)
- public/llms.txt + llms-full.txt (Entity Facts)

**MUST NOT TOUCH / PRESERVE**
- النص العربي المنشور الأخرى
- بنية JSON-LD الحالية (إضافة فقط)

**TASK**
1. اطلب من المالك رقم السجل التجاري الرسمي (الـ 10 أرقام).
2. أضف crNumber إلى src/data/site.ts.
3. في Footer.astro، أضف سطر "سجل تجاري: 1010XXXXXX" بالقرب من العنوان.
4. في schema generator، أضف `"taxID":"1010XXXXXX"` و `"identifier":"CR-1010XXXXXX"` لـ Organization.
5. في llms.txt Entity Facts، أضف سطر `Commercial Registration: 1010XXXXXX`.
6. في llms-full.txt، أضف قسم تفصيلي.

**ACCEPTANCE CRITERIA**
- `curl -s https://brightai.site/ | grep -oE 'سجل تجاري[^">*|1010[0-9]{6}'` → يرجع الرقم
- `curl -s https://brightai.site/ | grep -oE '"taxID":"[^"]*"'` → يرجع القيمة

**VERIFICATION COMMANDS**
```bash
curl -s https://brightai.site/ | grep -oiE "سجل تجاري|taxID|1010[0-9]{6}"
curl -s https://brightai.site/llms.txt | grep -i "commercial\|سجل"
```

ROLLBACK — git revert. تغيير محتوى فقط.

DEFINITION OF DONE — كل الصفحات + JSON-LD + llms.txt. CR ظاهر في footer
---
```

BAI-IDX-13 — إصلاح lastmod per-page في sitemap الإنتاجي

```
## PROMPT [ID: BAI-IDX-13] — lastmod per-page (git log) في الإنتاج
**Priority: P0 · Effort: 3h · Impact: 8 · Risk: low · Depends: BAI-DEPLOY-13 · Blocks: none**

**CONTEXT** — scripts/generate-sitemap-all-pages.mjs:21-29 contract يقول "lastmod derived from git log, never from build timestamp". الـ sitemap المحلي يحوي 9 تواريخ فريدة (صحيح). لكن الإنتاج يخدم 195 entry (تاريخ البناء فقط) كلها 29-07-2026. Google سيتجاهل lastmod لعدم مصداقيته. السبب المحتمل: خطوة build/override في pipeline الإنتاج تعيد كتابة lastmod.

**FILES IN SCOPE**
- scripts/generate-sitemap-all-pages.mjs (تحقق أن lastmod فعلاً من git log)
- build pipeline (astro.config.mjs أو render.yaml أو CI) — أين يُعاد كتابة lastmod
- public/sitemap.xml (مقارنة محلي vs إنتاج)
```

```
**MUST NOT TOUCH / PRESERVE**
- عدد URLs (195) — لا حذف
- ترتيب

**TASK**
1. قارن public/sitemap.xml مع (9 تواريخ) المحلي curl أكّد الفجوة (1 تاريخ). الإنتاج (1 تاريخ).
2. ابحث في pipeline: `grep -rn "lastmod" scripts/ astro.config.mjs .github/` — أين يُعاد كتابة.
3. إذا كان astro sitemap integration يُعيد كتابة، عطّله أو اضبطه يستخدم المصدر.
4. إذا كان Render build step، اضبطه ينسخ public/sitemap.xml بدون تعديل.
5. Deploy + تحقق.

**ACCEPTANCE CRITERIA**
- `curl -s https://brightai.site/sitemap.xml | grep "<lastmod>" | sort -u | wc -l` → ≥ 5 (ليس 1)

**VERIFICATION COMMANDS**
```bash
curl -s https://brightai.site/sitemap.xml | grep -c "<lastmod>"
curl -s https://brightai.site/sitemap.xml | grep "<lastmod>" | sort -u | wc -l
curl -s https://brightai.site/sitemap.xml | grep "<lastmod>" | sort -u | head
```

ROLLBACK — git revert + إعادة النشر.

DEFINITION OF DONE — sitemap الإنتاجي يحوي ≥5 تواريخ lastmod فريدة مشتقة من git log.

```

BAI-SAID-02 — توحيد هوية المؤسس "يزيد الشريف"

```
## PROMPT [ID: BAI-SAID-02] — توحيد اسم المؤسس + صورة + سيرة
**Priority: P0 · Effort: 2h · Impact: 8 · Risk: low · Depends: user-confirms-name · Blocks: BAI-SAID-05**

**CONTEXT** — JSON-LD Organization.founder.name = "يزيد" فقط (الاسم الأول) في homepage + about + schema-saudi-seo.json. لكن "يزيد الشريف" الاسم الكامل موجود في /authors/yazeed-alshareef/ الشمري" يظهر أيضًا في about (تناقض بيانات). avatar = حرف "ي" فقط، ليست <img>. لا سيرة مهنية بخبرات سابقة مسمّاة.

**FILES IN SCOPE**
- src/data/site.ts أو schema generator (founder name)
- src/data/schema-saudi-seo.json
- src/pages/about/ (نص + تناقض الشمري/الشريف)
- src/components (founder avatar → img)

**MUST NOT TOUCH / PRESERVE**
- النص العربي المنشور الأخرى
- LinkedIn URL الحالي

**TASK**
1. أكّد مع المالك: الاسم القانوني الكامل (الشريف أم الشمري؟).
2. حدّث JSON-LD founder.name أضف + الاسم الكامل إلى familyName + givenName.
3. أزل الاسم المتناقض من about (وحّد على القانوني).
4. استبدل founder avatar (حرف "ي") بـ <img src="/founder.jpg"> (صورة احترافية من المالك).
5. أضف سيرة مهنية قصيرة (خبرات سابقة مسمّاة) في about.
6. اربط LinkedIn حقيقي.

**ACCEPTANCE CRITERIA**
```

```
- `curl -s https://brightai.site/ | grep -oE '"founder":\{[^}]*"name":"[^"]*"'` → "name":"يزيد الشريف" (الاسم الكامل)
- `curl -s https://brightai.site/about/ | grep -c "<img.*founder\|founder.*img"` → ≥ 1

**VERIFICATION COMMANDS**
```bash
curl -s https://brightai.site/ | grep -oE '"name":"يزيد[^"]*"'
curl -s https://brightai.site/about/ | grep -oiE "الشريف|الشمري" | sort | uniq -c
```

ROLLBACK — git revert.

DEFINITION OF DONE — JSON-LD لا تناقض + سيرة + صورة حقيقية + موحّد على الاسم الكامل.

```

الـ 55-95 بروميت المتبقية (BAI-ARCH, BAI-PERF, BAI-A11Y, BAI-DESIGN, BAI-MOBILE, BAI-KERNEL, BAI-SAID, BAI-IDX, BAI-SEC, BAI-DEPLOY, BAI-MEAS, BAI-GROWTH) موجودة كاملة في ملف Markdown المنفصل باتباع نفس القالب الإلزامي.

ملحق — أوامر curl + القائمة المرجعية

أ.1 أوامر التحقق الإنتاجي (re-runnable)

```
# Deployment forensics
curl -sI https://brightai.site/ | grep -iE "last-modified|server|cf-"
curl -sI https://brightai.site/api/health/ -w "%{http_code}\n" -o /dev/null
curl -sI https://brightai.site/frontend/server.js -w "%{http_code}\n" -o /dev/null

# API liveness (CRITICAL — should pass after Node deploy)
curl -i -X POST https://brightai.site/api/ai/chat/ \
  -H "Origin: https://brightai.site" -H "Content-Type: application/json" \
  -d '{"message":"test"}' -w "\n[%{http_code}]\n"

# Sitemap lastmod
curl -s https://brightai.site/sitemap.xml | grep -c "<lastmod>"
curl -s https://brightai.site/sitemap.xml | grep "<lastmod>" | sort -u | wc -l

# Redirects
curl -sI https://brightai.site/blog | grep -i location
curl -sI https://brightai.site/report | grep -i location

# Key leak scan
grep -rn "AIzaSy" src/ scripts/ public/ 2>/dev/null | grep -v node_modules

# Security headers
curl -sI https://brightai.site/ | grep -iE "strict-transport|x-frame|x-
content|referrer|permissions"

# hreflang
curl -s https://brightai.site/en/privacy-policy/ | grep -oE 'hreflang="[^"]*"'

# Gemini key in tracked history
git log --all -S "AIzaSy" --oneline | head
```

أ.2 القائمة المرجعية للنشر (pre-deploy)

- □ npm run build → 195 صفحة، 0 أخطاء+
- □ npm run verify:all → exit 0
- □ npm run seo:all → exit 0
- □ npm run performance:budget → exit 0
- □ Render service = **Node Web Service** (ليس Static Site)
- □ env vars مضبوطة على Render dashboard
- □ POST /api/ai/chat/ بعد النشر → reply حقيقي
- □ api/health/ → JSON/ (ليس 404 HTML)
- □ x-brightai-build header حاضر
- □ Cloudflare cache purge
- □ IndexNow: npm run indexnow:deploy

أ.3 القائمة المرجعية للـ self-check

- ☑ كل ادعاء تحقّق منه بـ curl على الإنتاج
- ☑ قارنت v3 → v2 → v1 لكل محور (عمود Delta)
- ☑ اختبرت /api/ai/chat فعليًا — Gemini معطّل (Node لا يعمل)
- ☑ فحصت 11 صفحة kernel على 360px (Playwright مباشر)
- ☑ كل بند له SOURCE_STATE + PROD_STATE + Delta
- ☑ ذكرت [DATA GAP] و [ASSUMPTION — confidence] صراحةً
- ☑ تحذير أمني: مفتاح Gemini في لقطة الشاشة — يدوّر فورًا
- ☑ لا <title> غير مهرّب في محتوى الجداول

---

commit a8857c26 — 2026-07-29 — BrightAI Championship Audit v3 — طُوّر بمنهجية subagents + v1/v2 موازية + Playwright verification.